



Federal Financial Institutions Examination Council

FFIEC

Audit **AUD**

April 2012

IT EXAMINATION

HANDBOOK

Table of Contents

Introduction	1
IT Audit Roles and Responsibilities	2
Board of Directors and Senior Management	2
Audit Management	4
Internal IT Audit Staff	4
Operating Management	5
External Auditors	5
Independence and Staffing of Internal IT Audit	6
Independence	6
Staffing	7
Internal Audit Program	7
Risk Assessment and Risk-Based Auditing	10
Program Elements	10
Risk Scoring System	11
Audit Participation in Application Development, Acquisition, Conversions, and Testing	13
Outsourcing Internal IT Audit	14
Independence of the External Auditor Providing Internal Audit Services	15
Examples of Arrangements	15
Third-Party Reviews of Technology Service Providers	17
Appendix A: Examination Procedures	A-1
Appendix B: Glossary	B-1
Appendix C: Laws, Regulations, and Guidance	C-1

Introduction

This "Audit Booklet" is one of several booklets that comprise the Federal Financial Institutions Examination Council (FFIEC) Information Technology Examination Handbook (IT Handbook) and provides guidance to examiners and financial institutions on the characteristics of an effective information technology (IT) audit function. ^[1] This booklet replaces and rescinds Chapter 8 of the 1996 FFIEC Information Systems Examination Handbook. It should be used by examiners of the FFIEC member agencies ^[2] as a foundation from which they can assess the quality and effectiveness of an institution's IT audit program. It describes the roles and responsibilities of the board of directors, management, and internal or external auditors; identifies effective practices for IT audit programs; and details examination objectives and procedures. Agency examiners will use the examination procedures in Appendix A to assess the adequacy of IT audit programs at both financial institutions and technology service providers. The examination guidance and procedures in this booklet focus on IT audit and supplement other, more general, internal and external audit guidance provided by the FFIEC agencies. ^[3]

A well-planned, properly structured audit program is essential to evaluate risk management practices, internal control systems, and compliance with corporate policies concerning IT-related risks at institutions of every size and complexity. Effective audit programs are risk-focused, promote sound IT controls, ensure the timely resolution of audit deficiencies, and inform the board of directors of the effectiveness of risk management practices. An effective IT audit function may also reduce the time examiners spend reviewing areas of the institution during examinations. Ideally, the audit program would consist of a full-time, continuous program of internal audit coupled with a well-planned external auditing program.

The financial industry must plan, manage, and monitor rapidly changing technologies to enable it to deliver and support new products, services, and delivery channels. The rate of these changes and the resulting increased reliance on technology make the inclusion of IT audit coverage essential to an effective overall audit program. The audit program should address IT risk exposures throughout the institution, including the areas of IT management and strategic planning, data center operations, client/server architecture, local and wide-area networks, telecommunications, physical and information security, electronic banking, systems development, and business continuity planning. IT audit should also focus on how management determines the risk exposure from its operations and controls or mitigates that risk.

To determine what risks exist, management should prepare an independent assessment of the institution's risk exposure and the quality of the internal controls associated with the development, acquisition, implementation, and use of information technology. An institution's IT audit function can provide this independent assessment within the context of the overall audit function and can include work performed by both internal and external auditors and by other independent third parties as appropriate for the institution's complexity and level of internal expertise. The FFIEC member agencies believe that a strong internal auditing function combined with a well-planned external auditing function substantially increase the probability that an institution will detect potentially serious technology-related problems. An effective IT audit program should:

- Identify areas of greatest IT risk exposure to the institution in order to focus audit resources;
- Promote the confidentiality, integrity, and availability of information systems;
- Determine the effectiveness of management's planning and oversight of IT activities;
- Evaluate the adequacy of operating processes and internal controls;
- Determine the adequacy of enterprise-wide compliance efforts related to IT policies and internal control procedures; and
- Require appropriate corrective action to address deficient internal controls and follow up to ensure management promptly and effectively implements the required actions.

The examiner is responsible for evaluating the effectiveness of the IT audit function in meeting these objectives. The examiner should also consider the institution's ability to promptly detect and report significant risks to the board of directors and senior management. Examiners should take into account the institution's size, complexity, and overall risk profile when performing this and other evaluations. Examiners should consider the following issues when evaluating the IT audit function:

- Independence of the audit function and its reporting relationship to the board of directors or its audit committee;
- Expertise and size of the audit staff relative to the IT environment;
- Identification of the IT audit universe, risk assessment, scope, and frequency of IT audits;
- Processes in place to ensure timely tracking and resolution of reported weaknesses; and
- Documentation of IT audits, including work papers, audit reports, and follow-up.

IT Audit Roles and Responsibilities

Board of Directors and Senior Management

The board of directors and senior management are responsible for ensuring that the institution's system of internal controls operates effectively. One important element of an effective internal control system is an internal audit function that includes adequate IT coverage.

To meet its responsibility of providing an independent audit function with sufficient resources to ensure adequate IT coverage, the board of directors or its audit committee should:

- Provide an internal audit function capable of evaluating IT controls,
- Engage outside consultants or auditors to perform the internal audit function, or
- Use a combination of both methods to ensure that the institution has received adequate IT audit coverage.

An institution's board of directors may establish an "audit committee" to oversee audit functions and to report on audit matters periodically to the full board of directors. For purposes of this booklet, the term "audit committee" means the committee with audit oversight regardless of the type of financial institution. ^[4] Audit committee members should have a clear understanding of the importance and necessity of an independent audit function.

To comply with the Sarbanes-Oxley Act of 2002, ^[5] public stock-issuing institutions are required to appoint outside directors as audit committee members. All members of a stock-issuing institution's audit committee must be members of the board of directors and be independent (i.e., not otherwise compensated by, or affiliated with, the institution). Additionally, 12 CFR 363 (Federal Deposit Insurance Corporation Improvement Act, or FDICIA) requires all depository institutions with total assets greater than \$500 million to have independent audit committees. Although not all institutions are subject to these requirements due to their corporate structure (Sarbanes-Oxley) or their size (FDICIA), it is generally considered good practice that they use them as guidelines to ensure the independence of their audit committees.

The board of directors should ensure that written guidelines for conducting IT audits have been adopted. The board of directors or its audit committee should assign responsibility for the internal audit function to a member of management (hereafter referred to as the "internal audit manager") who has sufficient audit expertise and is independent of the operations of the business.

The board should give careful thought to the placement of the audit function in relation to the institution's management structure. The board should have confidence that the internal audit staff members will perform their duties with impartiality and not be unduly influenced by senior management and managers of day-to-day operations. Accordingly, the internal audit manager should report directly to the board of directors or its audit committee.

The board or its audit committee is responsible for reviewing and approving audit strategies (including policies and programs), and monitoring the effectiveness of the audit function. The board or its audit committee should be aware of, and understand, significant risks and control issues associated with the institution's operations, including risks in new products, emerging technologies, information systems, and electronic banking. Control issues and risks associated with reliance on technology can include:

- Inappropriate user access to information systems,
- Unauthorized disclosure of confidential information,
- Unreliable or costly implementation of IT solutions,

- Inadequate alignment between IT systems and business objectives,
- Inadequate systems for monitoring information processing and transactions,
- Ineffective training programs for employees and system users,
- Insufficient due diligence in IT vendor selection,
- Inadequate segregation of duties,
- Incomplete or inadequate audit trails,
- Lack of standards and controls for end-user systems,
- Ineffective or inadequate business continuity plans, and
- Financial losses and loss of reputation related to systems outages.

The board or its audit committee members should seek training to fill any gaps in their knowledge related to IT risks and controls. The board of directors or its audit committee should periodically meet with both internal and external auditors to discuss audit work performed and conclusions reached on IT systems and controls.

Audit Management

The internal audit manager is responsible for implementing board-approved audit directives. The manager oversees the audit function and provides leadership and direction in communicating and monitoring audit policies, practices, programs, and processes. The internal audit manager should establish clear lines of authority and reporting responsibility for all levels of audit personnel and activities. The internal audit manager also should ensure that members of the audit staff possess the necessary independence, experience, education, training, and skills to properly conduct assigned activities.

The internal audit manager should be responsible for internal control risk assessments, audit plans, audit programs, and audit reports associated with IT. Audit management should oversee the staff assigned to perform the internal audit work, should establish policies and procedures to guide the audit staff, and should ensure the staff has the expertise and resources to identify inherent risks and assess the effectiveness of internal controls in the institution's IT operations.

Internal IT Audit Staff

The primary role of the internal IT audit staff is to assess independently and objectively the controls, reliability, and integrity of the institution's IT environment. These assessments can help maintain or improve the efficiency and effectiveness of the institution's IT risk management, internal controls, and corporate governance.

Internal auditors should evaluate IT plans, strategies, policies, and procedures to ensure

adequate management oversight. Additionally, they should assess the day-to-day IT controls to ensure that transactions are recorded and processed in compliance with acceptable accounting methods and standards and are in compliance with policies set forth by the board of directors and senior management. Auditors also perform operational audits, including system development audits, to ensure that internal controls are in place, that policies and procedures are effective, and that employees operate in compliance with approved policies. Auditors should identify weaknesses, review management's plans for addressing those weaknesses, monitor their resolution, and report to the board as necessary on material weaknesses.

Auditors should make recommendations to management about procedures that affect IT controls. In this regard, the board and management should involve the audit department in the development process for major new IT applications. The board and management should develop criteria for determining those projects that need audit involvement. Audit's role generally entails reviewing the control aspects of new applications, products, conversions, or services throughout their development and implementation. Early IT audit involvement can help ensure that proper controls are in place from inception. However, the auditors should be careful not to compromise, or even appear to compromise, their independence when involved in these projects.

Operating Management

Operating management should formally and effectively respond to IT audit or examination findings and recommendations. The audit procedures should clearly identify the methods for following up on noted audit or control exceptions or weaknesses. Operating management is responsible for correcting the root causes of the audit or control exceptions, not just treating the exceptions themselves. Response times for correcting noted deficiencies should be reasonable and may vary depending on the complexity of the corrective action and the risk of inaction. Auditors should document, report, and track recommendations and outstanding deficiencies. Additionally, auditors should conduct timely follow-up audits to verify the effectiveness of management's corrective actions for significant deficiencies.

External Auditors

External auditors typically review IT control procedures as part of their overall evaluation of internal controls when providing an opinion on the adequacy of an institution's financial statements. As a rule, external auditors review the general and application controls affecting the recording and safeguarding of assets and the integrity of controls over financial statement preparation and reporting. General controls include the plan of organization and operation, documentation procedures, access to equipment and data files, and other controls affecting overall information systems operations. Application controls relate to specific information systems tasks and provide reasonable assurance that the recording, processing, and reporting of data are properly performed.

External auditors may also review the IT control procedures as part of an outsourcing arrangement in which they are engaged to perform all or part of the duties of the internal audit staff. Such arrangements are discussed in more detail in the "Outsourcing Internal IT Audit" section of this booklet.

The extent of external audit work, including work related to information systems, should be clearly defined in an engagement letter. Such letters should discuss the scope of the audit, the objectives, resource requirements, audit timeframe, and resulting reports. Examiners will typically review the engagement letter, reports, and audit work papers to determine the extent to which they can rely on external audit coverage and reduce their examination scope accordingly.

Independence and Staffing of Internal IT Audit

Independence

The ability of the internal audit function to achieve desired objectives depends largely on the independence of audit personnel. Generally, the position of the auditor within the organizational structure of the institution, the reporting authority for audit results, and the auditor's responsibilities indicate the degree of auditor independence. The board should ensure that the audit department does not participate in activities that may compromise, or appear to compromise, its independence. These activities may include preparing reports or records, developing procedures, or performing other operational duties normally reviewed by auditors.

The auditor's independence is also determined by analyzing the reporting process and verifying that management does not interfere with the candor of the findings and recommendations. For an effective program, the board should give the auditor the authority to:

- Access all records and staff necessary to conduct the audit, and
- Require management to respond formally, and in a timely manner, to significant adverse audit findings by taking appropriate corrective action.

Internal auditors should discuss their findings and recommendations periodically with the audit committee or board of directors.

Ideally, the internal audit manager should report directly to the board of directors or its audit committee regarding both audit issues and administrative matters.^[6] Alternatively, an institution may establish a dual reporting relationship where the internal audit manager reports to the audit committee or board for audit matters and to institution executive management for administrative matters. The objectivity and organizational stature of the internal audit function are best served under such a dual arrangement if the internal audit manager reports administratively to the chief executive office (CEO), and not to the chief financial officer (CFO) or a similar officer who has a direct responsibility for systems being audited. The board or its audit committee should determine the internal audit manager's performance evaluations and compensation.

The formality and extent of an institution's internal IT audit function depends on the institution's size, complexity, scope of activities, and risk profile. It is the responsibility of the audit committee and management to carefully consider the extent of auditing that will

effectively monitor the internal control system subject to consideration of the internal audit function's costs and benefits. For larger institutions or institutions with complex operations, the benefits derived from a full time manager of internal audit or an audit staff will likely outweigh the cost. For small institutions with few employees and/or simple operations, these costs may outweigh the benefits. Nevertheless, an institution without an internal auditor can ensure that it maintains an objective and independent internal function by implementing comprehensive internal reviews of significant internal controls. The key characteristic of such reviews is that the person(s) directing or performing the review is (are) not also responsible for managing or operating those controls.

Staffing

Personnel performing IT audits should have information systems knowledge commensurate with the scope and sophistication of the institution's IT environment and possess sufficient analytical skills to determine and report the root cause of deficiencies. If internal expertise is inadequate, the board should consider using qualified external sources such as management consultants, independent auditors, or other professionals to supplement or perform the institution's internal IT audit function. In some institutions, a person or group that has no other responsibilities outside the IT audit function performs IT audits. Generally, institutions using this approach centralize IT audit coverage and assign one or more IT audit specialists to perform end-user application control reviews as well as technical system audits. A centralized IT audit department can ensure sufficient technical expertise, but can also strain technical resources and require multiple audits in a user department. Additionally, IT auditors in this environment may need to have a greater understanding of financial and business line audit concerns.

Other institutions may use an integrated audit approach. Using this method, IT audit specialists perform the technology system and other technical reviews, while generalist auditors perform the end-user application control reviews. Institutions should use auditors with technical knowledge appropriate for the areas reviewed.

An institution's hiring and training practices should ensure that the institution has qualified IT auditors. The auditor's education and experience should be consistent with job responsibilities. Audit management should also provide an effective program of continuing education and development. As the information systems of an institution become more sophisticated or as more complex technologies evolve, the auditor may need additional training.

Internal Audit Program

Action Summary

Management should develop and follow a formal internal audit program consisting of policies and procedures that govern the internal audit function, including IT audit.

An institution's internal audit program consists of the policies and procedures that govern its internal audit functions, including risk-based auditing programs and outsourced internal audit work, if applicable. While smaller institutions' audit programs may not require the formality of those found in larger, more complex institutions, all audit programs should include

- A mission statement or audit charter outlining the purpose, objectives, organization, authorities, and responsibilities of the internal auditor, audit staff, audit management, and the audit committee.
- A risk assessment process to describe and analyze the risks inherent in a given line of business. Auditors should update the risk assessment at least annually, or more frequently if necessary, to reflect changes to internal control or work processes, and to incorporate new lines of business. The level of risk should be one of the most significant factors considered when determining the frequency of audits.
- An audit plan detailing internal audit's budgeting and planning processes. The plan should describe audit goals, schedules, staffing needs, and reporting. The audit plan should cover at least 12 months and should be defined by combining the results of the risk assessment and the resources required to yield the timing and frequency of planned internal audits. The audit committee should formally approve the audit plan annually, or review it annually in the case of multi-year audit plans. The internal auditors should report the status of planned versus actual audits, and any changes to the annual audit plan, to the audit committee for its approval on a periodic basis.
- An audit cycle that identifies the frequency of audits. Auditors usually determine the frequency by performing a risk assessment, as noted above, of areas to be audited. While staff and time availability may influence the audit cycle, they should not be overriding factors in reducing the frequency of audits for high-risk areas.
- Audit work programs that set out for each audit area the required scope and resources, including the selection of audit procedures, the extent of testing, and the basis for conclusions. Well-planned, properly structured audit programs are essential to strong risk management and to the development of comprehensive internal control systems.
- Written audit reports informing the board and management of individual department or division compliance with policies and procedures. These reports should state whether operating processes and internal controls are effective, and describe deficiencies as well as suggested corrective actions. The audit manager should consider implementing an audit rating system (for example, satisfactory, needs improvement, unsatisfactory) approved by the audit committee. The rating system facilitates conveying to the board a consistent and concise assessment of the net risk posed by the area or function audited. All written audit reports should reflect the assigned rating for the areas audited.
- Requirements for audit work paper documentation to ensure clear support for all audit findings and work performed, including work paper retention policies.
- Follow-up processes that require internal auditors to determine the disposition of any agreed-upon actions to correct significant deficiencies.